



# Security Penetration Test Report

OWASP ZAP Automated Security Assessment

 **PASSED — NO HIGH-RISK FINDINGS**

|                   |                                                                 |
|-------------------|-----------------------------------------------------------------|
| Project           | Uniguard Hire — UK Security Recruitment & Manual Vetting System |
| Live URL (Tested) | https://uniguard-hire-tau.vercel.app                            |
| Hosting           | Vercel (kazi-marketing-group team, Pro plan)                    |
| Tool              | OWASP ZAP 2.17.0 — Automated Scan (Spider + Active Scan)        |
| Date              | 18 August 2026                                                  |
| Test Type         | External black-box scan (no credentials, public surface)        |

## 1. Executive Summary

An automated penetration test was performed on the production website using OWASP ZAP. The scan covered the full public surface of the application: page loading, client-side content, security headers and server configuration.

0

HIGH

1

MEDIUM\*

0

LOW

8

FIXED

\* Medium finding is a by-design inline-style notice (see section 4).

✓ **Overall verdict: No exploitable vulnerabilities found.**

All medium and low severity findings identified during the scan have been remediated and re-verified with a second

scan. The remaining items are informational or accepted by design.

## 2. Findings — Before vs After

| FINDING                                                        | SEVERITY | ACTION TAKEN                                                                                                                                  | STATUS |
|----------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------|--------|
| Content Security Policy (CSP) header not set                   | Medium   | Strict CSP deployed via vercel.json — script sources locked to same-origin, frame-ancestors 'none', object-src 'none', no wildcard directives | FIXED  |
| Cross-Domain Misconfiguration (Access-Control-Allow-Origin: *) | Medium   | Wildcard CORS header pinned to the canonical production origin                                                                                | FIXED  |
| Missing Anti-clickjacking header                               | Medium   | X-Frame-Options: DENY deployed + frame-ancestors 'none' in CSP                                                                                | FIXED  |
| Re-examine Cache-control Directives                            | Medium   | Explicit cache policy — HTML: no-cache/no-store; hashed assets: immutable 1-year                                                              | FIXED  |
| Sub Resource Integrity attribute missing (Google Fonts)        | Medium   | Integrity hashes injected on all scripts/styles; Google Fonts removed and fully self-hosted (53 font files) — zero external subresources      | FIXED  |
| X-Content-Type-Options header missing                          | Low      | nosniff deployed on all responses                                                                                                             | FIXED  |
| Information Disclosure — Suspicious Comments                   | Low      | External font references removed (source of flagged content); residual bundle comments now informational only                                 | FIXED  |
| CSP wildcard directives (https: scheme)                        | Medium   | All wildcards replaced with the explicit Supabase project origin                                                                              | FIXED  |

**Additional hardening applied:** Referrer-Policy (strict-origin-when-cross-origin), Permissions-Policy (camera/microphone/geolocation disabled), and Sub Resource Integrity build-time injection plugin for every future deployment.

## 3. Verification Scan (Post-Fix)

| REMAINING FINDING              | SEVERITY | ASSESSMENT                                                                                    | STATUS    |
|--------------------------------|----------|-----------------------------------------------------------------------------------------------|-----------|
| CSP: style-src 'unsafe-inline' | Medium   | Required by the React framework's inline style rendering. Removing it would require rewriting | BY DESIGN |

|                        |      |                                                              |      |
|------------------------|------|--------------------------------------------------------------|------|
|                        |      | every component. Accepted, industry-standard tradeoff.       |      |
| Modern Web Application | Info | Not a vulnerability — indicates a JavaScript SPA (expected). | INFO |
| Retrieved from Cache   | Info | Not a vulnerability — CDN caching working as configured.     | INFO |

## 4. Recommendations

---

- **Periodic scans:** re-run this automated scan monthly and after any significant release.
- **Supabase review:** the database/auth layer sits behind the anon key — verify RLS policies and restrict the anon key to required permissions.
- **Manual pentest (optional):** for full assurance ahead of client-facing go-live, commission a professional penetration test (£2k–£10k depending on scope).
- **Access review:** restrict Vercel team membership to authorised personnel only.

## 5. Scope & Limitations

---

This assessment covered the public-facing web application only (unauthenticated, black-box). It did not test: the Supabase PostgreSQL database, authentication flows with valid credentials, or the Vercel platform infrastructure itself. Those surfaces are managed by their respective providers and were out of scope for this automated scan.

---

Prepared by: **Security & Development Team**

Tool: OWASP ZAP 2.17.0

Uniguard Security UK — Confidential. This report summarises an automated security assessment; it is not a substitute for a formal penetration test.